

## # Day 2 - Production Security Hardening Review

### ## Objective

Review the remaining built-in production security scan warnings, fix only safe confirmed issues, avoid auth weakening, avoid destructive host changes, avoid ``.env`` edits, and document exact owner/admin actions for host-level items.

### ## Result

**\*\*PARTIAL / HARDENING ITEMS REMAIN.\*\*** The production security score improved from the prior accepted 72/100 baseline to 78/100. ``.auth_pass`` now passes. ``.linux_mac_framework`` now passes because AppArmor is active. Remaining issues are either environment/config hardening that requires an approved OpenClaw+ config change, ``.env`` change, or host/admin decision.

No automatic fix route was run because the available fix route can mutate ``.env`` and runtime configuration. This phase was review-only.

### ## Updated Percentage

| System                      | Previous | Current  | Decision                               |
|-----------------------------|----------|----------|----------------------------------------|
| Production security scan    | 72%      | 78%      | PARTIAL                                |
| Credential posture          | Partial  | Improved | <code>`.auth_pass`</code> now PASS     |
| Host hardening              | Partial  | Partial  | Admin/owner decisions remain           |
| OpenClaw+ runtime hardening | Partial  | Partial  | Config review required before mutation |

### ## Actions

| Action                              | Result                                                     |
|-------------------------------------|------------------------------------------------------------|
| Reviewed each listed hardening item | PASS                                                       |
| Fixed safe confirmed issues         | None applied; no safe no-restart/no-env mutation available |
| Weakened auth                       | No                                                         |
| Made destructive host changes       | No                                                         |
| Modified <code>`.env`</code>        | No                                                         |
| Ran security auto-fix route         | No                                                         |
| Confirmed security scan auth        | Unauthenticated route returns HTTP 401                     |
| Documented owner/admin actions      | PASS                                                       |

### ## Commands And Routes Used

| Command / Route                                        | Purpose                                                                | Result             |
|--------------------------------------------------------|------------------------------------------------------------------------|--------------------|
| <code>`.GET /api/security-scan`</code> authenticated   | Production security scan                                               | HTTP 200, score 78 |
| <code>`.GET /api/security-scan`</code> unauthenticated | Auth protection                                                        | HTTP 401           |
| Source review of security auto-fix route               | Check whether fixes would mutate <code>`.env`</code> or runtime config | Auto-fix skipped   |

### ## Proof

Current scan summary:

| Field                       | Value    |
|-----------------------------|----------|
| score                       | 78       |
| unauthenticated access      | HTTP 401 |
| <code>`.env`</code> changed | false    |

```
| auth weakened | false |
| host changes applied | false |
```

Item-by-item review:

```
| ID | Status | Severity | Current Detail | Decision |
| --- | --- | --- | --- | --- |
| `auth_pass` | pass | critical | Strong non-default admin password configured | No action |
| `hsts_enabled` | warn | medium | HSTS not enabled | Requires approved HTTPS/header config and `.env`/service change; not changed here |
| `exec_restricted` | warn | high | OpenClaw+ exec security is full | Requires OpenClaw+ config hardening review; not mutated in security phase |
| `tools_deny_list` | warn | low | No tool deny list configured | Requires OpenClaw+ per-agent deny-list design; not guessed |
| `sandbox_mode` | warn | medium | Sandbox mode off | Requires OpenClaw+ runtime compatibility review |
| `backup_recent` | warn | medium | No backup directory | Requires backup policy/storage decision |
| `receipt_signing` | warn | medium | No MCP calls logged in last 24h | Needs receipt-signing traffic/proof, not a fake call |
| `firewall` | warn | critical | No firewall detected | Host/admin action required |
| `open_ports` | fail | medium | 31 listening ports detected | Host/admin review required; no ports closed blindly |
| `disk_encryption` | warn | high | No encrypted volumes detected | Host/admin/storage decision required |
| `linux_core_dumps` | warn | medium | Core pattern writes to file | Host/admin kernel setting required |
| `linux_mac_framework` | pass | high | AppArmor active | No action |
| `linux_tmp_noexec` | warn | medium | Temporary directory may allow execution | Host/admin mount option required |
```

## Files Changed

```
| File | Change |
| --- | --- |
| `runtime/day-02-production-security-hardening-review.md` | Added this report |
| `runtime/day-02-production-security-hardening-review.pdf` | Generated PDF report |
```

No application code or configuration was changed in this phase.

## Tests

```
| Test | Result |
| --- | --- |
| Authenticated security scan | PASS |
| Unauthenticated security scan | PASS, HTTP 401 |
| `.env` diff check | PASS, no `.env` edits |
| Auth weakening check | PASS, no auth change |
| Host mutation check | PASS, no destructive host changes |
| Secret exposure check | PASS |
```

## Services

```
| Service | State |
| --- | --- |
| Mission Control | Active |
| OpenClaw+ | Not changed in this phase |
| Host firewall/OS settings | Not changed in this phase |
```

## ## Blockers

| Blocker                                    | Impact                                           | Exact Next Step                                                                             |
|--------------------------------------------|--------------------------------------------------|---------------------------------------------------------------------------------------------|
| `hsts_enabled`                             | Browser/network hardening incomplete             | Approve HTTPS/HSTS runtime setting and service restart plan; no `.env` change was made here |
| `openclaw_exec_restricted_review_required` | OpenClaw+ exec remains too permissive per scan   | Review OpenClaw+ runtime compatibility, then set exec security to deny/allowlist if safe    |
| `openclaw_tools_deny_list_review_required` | Per-agent tool deny-list not configured          | Design deny-list by role so runtime is not broken                                           |
| `openclaw_sandbox_mode_review_required`    | Sandbox mode remains off                         | Validate sandbox compatibility, then enable scoped sandbox                                  |
| `backup_policy_required`                   | Recent backup proof missing                      | Configure/verify backup location and retention                                              |
| `receipt_signing_activity_required`        | Receipt signing proof lacks recent call activity | Generate or verify a legitimate MCP receipt-producing action; do not fake a call            |
| `host_firewall_admin_required`             | Firewall not detected                            | Owner/admin enables firewall with allowed ports reviewed                                    |
| `open_ports_admin_review_required`         | 31 listening ports require review                | Owner/admin audits and closes unnecessary host services                                     |
| `disk_encryption_admin_decision_required`  | Disk encryption is a host/storage decision       | Owner/admin decides encryption scope                                                        |
| `linux_core_dumps_admin_required`          | Kernel core dump policy needs hardening          | Owner/admin applies kernel/sysctl change                                                    |
| `linux_tmp_noexec_admin_required`          | Temporary directory mount hardening needs admin  | Owner/admin applies mount options if compatible                                             |

## ## Rollback

No code, `.env`, service, or host changes were made. Rollback is not required. If this report needs removal, revert the report-only commit that adds it.

## ## No-Secrets Confirmation

No password value, token, API key, auth file, `.env` content, or secret-shaped value was printed or committed.

## ## Final Decision

Production security remains **\*\*PARTIAL\*\*** at 78/100. The scan improved, but host-level and OpenClaw+ runtime hardening items remain and should be handled in explicit scoped hardening phases rather than by automatic mutation.